

Security risk assessment report

Review the following scenario. Then complete the step-by-step instructions.

You are a security analyst working for a social media organization. The organization recently experienced a major data breach, which compromised the safety of their customers' personal information, such as names and addresses. Your organization wants to implement strong network hardening practices that can be performed consistently to prevent attacks and breaches in the future.

After inspecting the organization's network, you discover four major vulnerabilities. The four vulnerabilities are as follows:

1. The organization's employees' share passwords.
2. The admin password for the database is set to the default.
3. The firewalls do not have rules in place to filter traffic coming in and out of the network.
4. Multifactor authentication (MFA) is not used.

If no action is taken to address these vulnerabilities, the organization is at risk of experiencing another data breach or other attacks in the future.

In this activity, you will write a security risk assessment to analyze the incident and explain what methods can be used to further secure the network.

Part 1: Select up to three hardening tools and methods to implement

The organization should implement Multifactor authentication (MFA), have stronger password policies, and perform firewall maintenance.

Part 2: Explain your recommendations

The organization should implement the above three hardening tools and methods. First is the MFA because the employees do not use MFA currently and it allows for 2 or more ways to confirm the identity of the person trying to access the system or network and this can include PIN or one-time passwords. Furthermore, this limits employees from sharing passwords because they

would need to have an additional way of authentication meaning passwords would be less likely to be shared.

Furthermore, there should be stronger password policies because the current password for the database is the default meaning anyone can crack the password if it is simple enough in a brute force attack fashion and therefore having salted/hashed passwords makes it harder for the attacker to crack the password. This also allows the attacker to be less likely to guess the password and limits the number of times they can guess which can prevent brute force attacks. There would be an increasingly longer password complexity required.

Lastly, firewall maintenance would need to occur to keep the firewall updated to current standards and where traffic from suspicious sources will be placed on a denied traffic list and firewall rules are updated whenever there is a security event that occurs and helps protect against DoS and DDoS attacks.